CYBR 550 — Assignment 3

Network Security Architecture & Defense Strategy

Northwestern Medicine

Prepared by: **Maxine Jones**

CYBR 550 | April 2026

Assignment continuity

- Assignment 1 — Axonius asset management (Northwestern Medicine)
- Assignment 2 — Purdue Model network architecture (6-zone)
- Assignment 3 — Security controls overlay on A2 network map

Design philosophy

Layered defense
Controls at every zone boundary

Intentional placement
Right tool, right location

Zero Trust aligned
Never trust, always verify

Realistic trade-offs
Usability balanced with risk

Key Security Principles — Northwestern Medicine

The five principles that guide every architectural decision in this security design

Why this matters for healthcare: A breach at Northwestern Medicine does not just mean lost data — it means disrupted patient care, HIPAA liability, and direct risk to patient safety, making layered security not optional but essential.

ZT

Zero Trust

No user, device, or application is trusted by default — regardless of whether it is inside or outside the network perimeter. Every access request must be authenticated, authorized, and continuously verified.

Applied in this design:

Okta SSO + MFA on every login · Zscaler ZTNA replaces VPN · CyberArk enforces zero standing privileges for vendors and admins

LP

Least Privilege

Every user, system, and application is granted only the minimum level of access required to perform its function — nothing more.

Applied in this design:

RBAC on Epic EHR limits PHI by role · ZTNA grants app-level access only · Vendor credentials expire on ticket close · Zone 1 devices cannot reach EHR directly

SG

Segmentation

The network is divided into isolated zones with controlled communication paths between them, so that a compromise in one area cannot automatically spread to others.

Applied in this design:

Six Purdue Model zones with dedicated VLANs and subnets · Internal firewalls at every zone boundary · Zone 1 biomedical devices air-gap adjacent

DD

Defense in Depth

Multiple overlapping layers of security controls are deployed so that if one layer fails, others remain in place to detect, contain, or stop a threat.

Applied in this design:

NGFW → IPS → ZTNA → Segmentation FW → NAC → EDR → SIEM — attacker must defeat every layer independently

VE

Visibility Everywhere

The security team maintains continuous awareness of every asset, session, and event across all zones — on-premises and cloud — so no blind spots exist for attackers to hide in.

Applied in this design:

Axonius unified inventory across all VLANs · Splunk aggregates logs from all zones · Sentinel forwards cloud alerts to on-prem SOC · H-ISAC threat intel integrated

Security Architecture Overlay — Northwestern Medicine

Assignment 2 network map with security controls overlaid at each zone boundary | † = security control added for Assignment 3

In healthcare, every zone boundary is a patient safety boundary — a breach that moves from Zone 4 to Zone 2 could disrupt Epic EHR or life-critical biomedical devices.

Zone 5 — External / Internet | untrusted | 165.124.x.x

Zone 4 — DMZ | VLAN 10 | 10.0.0.0/24

Zone 3 — Enterprise IT | VLAN 20–50 | 10.1.0.0/16

Zone 2 — Clinical / EHR | VLAN 60–90 | 10.2.0.0/16

Zone 1 — Biomedical / OT / IoT | VLAN 100–140 | 10.3.0.0/16 | air-gap adjacent

Zone 0 — Physical + Cloud Azure Gov | 172.16.0.0/16

† HID badge + mantrap · † CCTV · † ExpressRoute (private) · † Defender for Cloud · † Sentinel → Splunk · † Immutable DR backup

Attacker path — stopped at each boundary: Z5 → NGFW blocks · Z4 → ZTNA denies broad access · Z3 → Seg. FW + NAC stops pivot · Z2 → Microseg FW contains blast · Z1 → Air-gap absorbs · SOC alerted at every step

Untrusted | DMZ | Enterprise IT | Clinical | OT/IoT | Physical+Cloud

Security Architecture Overview — Layered Controls Across All Zones

Building directly on the Assignment 2 Purdue Model network map | Northwestern Medicine

Zone 5 — External / Internet (untrusted)

Remote clinicians · Telehealth patients · Vendors · Patient portal · ISP

NGFW + IPS

Zone 4 — DMZ / Screened Network | VLAN 10 | 10.0.0.0/24

Palo Alto NGFW · Cisco Firepower IPS · Zscaler ZTNA · F5 WAF · DNS/NTP forwarders

WAF ZTNA IPS

Zone 3 — Enterprise IT / Corporate | VLAN 20–50 | 10.1.0.0/16

Azure AD · Okta SSO · CyberArk PAM · Splunk · CrowdStrike · Axonius · SCCM/Intune

SIEM EDR IAM PAM

Zone 2 — Clinical Network / EHR | VLAN 60–90 | 10.2.0.0/16

Epic EHR · PACS (Sectra) · Telehealth · Clinical workstations · HL7/FHIR APIs

NAC RBAC Audit logs

Zone 1 — Biomedical / OT / IoT | VLAN 100–140 | 10.3.0.0/16

Infusion pumps · Patient monitors · Imaging devices · HVAC/BMS · IoT (isolated VLAN)

NAC Passive NDR ACLs

Zone 0 — Physical + Cloud (Azure Gov) | 172.16.0.0/16

Galter DC · UPS/gen · Badge access · Azure ExpressRoute · Sentinel · Defender · Backup/DR

MFA Encrypt DR Defender

Security controls are strategically placed at each zone boundary. Controls are enforced at the point where trust levels change — not uniformly applied everywhere.

Layers of Defense — Network, Endpoint, Identity, Monitoring

How the four security layers work together across the Northwestern Medicine environment

Network Security

- Palo Alto NGFW HA pair at Zone 5/4 boundary
- Cisco Firepower IPS — inline blocking, Snort 3
- F5 BIG-IP WAF — OWASP rules + FHIR/HL7 API gateway
- Zscaler ZTNA — app-level access, no lateral movement
- Cisco Catalyst 9000 + ISE NAC — port-level enforcement
- Microsegmentation between all Purdue Model zones
- Dual-vendor firewall (Palo Alto + Cisco) — no single vendor risk

Endpoint Security

- CrowdStrike Falcon EDR — all enterprise + clinical endpoints
- SCCM + Intune + JAMF — patch management, device compliance
- Cisco ISE NAC — device posture check before network access
- Axonius — continuous asset inventory across all VLANs
- Smart card + MFA on all clinical workstations
- Legacy biomedical devices isolated in Zone 1 VLANs
- Passive NDR tools — monitor OT/IoT without agents

Identity & Access

- Azure Active Directory + Okta SSO — enterprise identity
- MFA enforced for all remote access + vendor sessions
- CyberArk PAM — privileged + vendor session recording
- RBAC on Epic EHR — role-limited PHI access
- Time-limited vendor credentials via CyberArk
- Conditional access policies — device posture required
- Zero standing privileges for third-party accounts

Monitoring & Detection

- Splunk SIEM — on-prem log aggregation, all zones
- Microsoft Sentinel — cloud SIEM + SOAR automation
- QRadar — complementary detection coverage
- Axonius — real-time asset state + security gap alerts
- Logs forwarded from all zones to Zone 3 SOC
- Cloud telemetry from Azure forwarded to on-prem SOC
- H-ISAC threat intel feeds integrated into SIEM

Risk Analysis & Key Enforcement Points

How the architecture reduces realistic risks across the Northwestern Medicine environment

Top risks and architectural mitigations

HIGH	**Ransomware lateral movement** Microsegmentation + ISE NAC limits blast radius to one VLAN. Zone 1 air-gap prevents OT pivot.
HIGH	**Compromised vendor credential** ZTNA grants app-only access. CyberArk records session, auto-revokes on ticket close.
MED	**Unmanaged / shadow IoT device** Cisco ISE NAC quarantines non-compliant devices. Axonius flags unknowns in real time.
HIGH	**PHI exfiltration via EHR** RBAC limits PHI access by role. Splunk SIEM alerts on anomalous Epic access patterns.
MED	**Legacy biomedical device exploit** Zone 1 isolation + ACLs + passive NDR. No patching required — containment is the control.
HIGH	**Command-and-control callback** NGFW + IPS inspects all outbound. Zscaler proxy blocks unauthorized C2 communications.

Key enforcement & monitoring points

Z5 → Z4
Palo Alto NGFW
First inspection. All traffic blocked by default.

Z4 DMZ
IPS + WAF + ZTNA
Threat detection, API security, vendor proxy.

Z4 → Z3
Internal FW
Enforces trust boundary between DMZ and IT.

Z3 → Z2
Segmentation FW
Protects clinical zone from enterprise zone.

Z2 → Z1
Microsegment FW + NAC
Isolates biomedical devices from clinical IT.

Z3 SOC
Splunk + Sentinel
Central log aggregation from all zones.

Cloud
ExpressRoute + Defender
Private connectivity, cloud-side EDR+SIEM.

System Integration, Trade-offs & Architectural Rationale

How controls interact and why each decision was made for Northwestern Medicine specifically

How security components interact

Axonius feeds Splunk + ISE

Axonius aggregates asset data from CrowdStrike, Cisco ISE, Azure AD, and Intune into a unified inventory. This inventory is shared with Splunk for enriched alerting and with ISE for dynamic NAC policy decisions — so if a device falls out of compliance, ISE can quarantine it automatically without human intervention.

ZTNA + CyberArk govern vendor sessions end-to-end

When a vendor connects, Zscaler ZTNA verifies identity via Okta MFA and grants access only to the approved application. CyberArk then records the session, enforces time limits, and revokes credentials on ticket close. Splunk ingests the session log, providing the SOC with a complete audit trail.

Zone 1 containment without agents

Legacy biomedical devices in Zone 1 cannot run EDR agents. Instead, passive NDR tools monitor traffic behavior without touching the device. ISE NAC enforces access at the switch port level. Axonius tracks all Zone 1 assets through ISE and PACS integrations, maintaining visibility without intrusive scanning.

Cloud telemetry closes the hybrid gap

Azure Sentinel and Defender for Cloud forward logs and alerts to the on-prem Splunk SOC via ExpressRoute. This ensures that the security team has unified visibility across on-premises and cloud workloads, and that cloud-side incidents trigger the same response workflows as on-prem events.

Design trade-offs

ZTNA vs. VPN

ZTNA replaces VPN for all remote access. Trade-off: higher complexity, but eliminates network-wide exposure from a single compromised VPN credential.

Dual-vendor firewall

Palo Alto + Cisco Firepower at the perimeter. Trade-off: increased operational overhead, but eliminates single-vendor risk and improves detection coverage.

Agent-less Zone 1

Legacy OT/biomedical devices cannot run EDR. Trade-off: lower endpoint visibility, compensated by passive NDR, NAC isolation, and Axonius asset tracking.

ExpressRoute over internet

Azure connected via private ExpressRoute rather than public internet. Trade-off: higher cost, but PHI never traverses untrusted networks.

No perimeter-only trust

Zero Trust means every zone has its own controls even if an attacker bypasses the outer firewall. Trade-off: more tools to manage, but significantly reduces blast radius.